



# Universidad de Oriente

Facultad de Ingeniería y Arquitectura  
Ingeniería En Desarrollo de Software

## Catedra

Ciberseguridad

## Proyecto Final

Manual Empresarial de Ciberseguridad

## Nombre de la empresa:

Construservices

## Rubro:

Construcción

## Catedrático

MBA. Ing. Rolando Josías Colato

## Estudiantes

Josué Iván Beltrán - U20230723

Marilyn Michelle Jiménez Arias - U20231085

## Fecha de elaboración:

San Miguel, 12 de Junio de 2026

## Detalles del documento

**Título del documento:**

Manual Empresarial de Ciberseguridad

**Versión del manual:**

V 1.0

**Responsables de elaboración**

Josué Iván Beltrán

Marilyn Michelle Jiménez Arias

**Nivel de confidencialidad del documento:**

Uso interno

**Nombre de la empresa:**

Construservices

**Rubro:**

Construcción

**Fecha de elaboración:**

12-06-2026

## Control de Versiones

### CONTROL DE VERSIONES

| Versión | Fecha      | Responsable(s)                    | Descripción del Cambio                                                                             |
|---------|------------|-----------------------------------|----------------------------------------------------------------------------------------------------|
| 0.1     | 23/05/2026 | Josué Beltrán,<br>Marilyn Jiménez | Creación inicial del documento y definición del alcance del proyecto.                              |
| 0.5     | 30/05/2026 | Josué Beltrán,<br>Marilyn Jiménez | Incorporación del inventario de activos, análisis de riesgos y marcos de referencia.               |
| 0.8     | 06/06/2026 | Josué Beltrán,<br>Marilyn Jiménez | Desarrollo de arquitectura de red, controles de seguridad, monitoreo y respuesta a incidentes.     |
| 1.0     | 12/06/2026 | Josué Beltrán,<br>Marilyn Jiménez | Revisión final, corrección de contenido, incorporación de conclusiones, roadmap y anexos técnicos. |

# Índice

|                                                                   |           |
|-------------------------------------------------------------------|-----------|
| Detalles del documento .....                                      | 2         |
| Control de Versiones.....                                         | 3         |
| Índice .....                                                      | 4         |
| <b>Introducción y contexto organizacional .....</b>               | <b>8</b>  |
| Perfil de la empresa.....                                         | 8         |
| Alcance del análisis de ciberseguridad .....                      | 9         |
| <b>Objetivos .....</b>                                            | <b>10</b> |
| Objetivo general .....                                            | 10        |
| Objetivos específicos .....                                       | 10        |
| Marcos de referencia y estándares utilizados .....                | 11        |
| <b>Inventarió de activos de información .....</b>                 | <b>12</b> |
| Clasificación y Valoración de Activos de la información .....     | 12        |
| Matriz de Activos de la Información.....                          | 12        |
| Activos de Hardware .....                                         | 13        |
| Identificación de Usuarios y Roles .....                          | 14        |
| <b>ANÁLISIS Y EVALUACIÓN DE RIESGOS.....</b>                      | <b>15</b> |
| Según la norma ISO/IEC 27001 .....                                | 15        |
| Metodología de evaluación de riesgos .....                        | 15        |
| Matriz de probabilidad e impacto .....                            | 17        |
| Matriz de riesgos .....                                           | 18        |
| Justificación del SIEM y EDR/XDR.....                             | 19        |
| Evaluación de Madurez de Ciberseguridad .....                     | 19        |
| <b>Mapeo de amenazas mediante el marco MITRE ATT&amp;CK .....</b> | <b>21</b> |
| <b>Amenazas y mitigaciones según fases .....</b>                  | <b>23</b> |
| Fase de reconocimiento.....                                       | 23        |
| Fase de Acceso inicial.....                                       | 23        |
| <b>Intérprete de comandos y scripts .....</b>                     | <b>24</b> |
| Fase de exfiltración o impacto.....                               | 24        |
| <b>Arquitectura de red .....</b>                                  | <b>25</b> |
| Diagnóstico de red actual .....                                   | 25        |
| Arquitectura de red segura .....                                  | 25        |

|                                                                                              |    |
|----------------------------------------------------------------------------------------------|----|
| Infraestructura Física y Cableado Estructurado (Cumplimiento TIA/EIA-568 e ISO 27001 A.7.10) | 26 |
| Perímetro de Red y Seguridad Fronteriza                                                      | 26 |
| Segmentación Lógica de la Red (Mitigación de Impacto e ISO 27001 A.8.22)                     | 27 |
| <b>Seguridad a nivel de aplicación y sistemas de gestión</b>                                 | 29 |
| Sistema de Gestión Interna (ERP y Repositorio de Información)                                | 29 |
| Sistema de Administración de Herramientas y Maquinaria                                       | 30 |
| Implementación de backups en archivos                                                        | 31 |
| <b>MONITOREO, DETECCIÓN Y OPERACIONES DE SEGURIDAD (SecOps)</b>                              | 32 |
| Estrategia de Monitoreo Continuo de la Infraestructura                                       | 32 |
| Implementación de Soluciones SIEM (Security Information and Event Management)                | 33 |
| Despliegue de Agentes EDR/XDR en Estaciones de Trabajo y Servidores                          | 33 |
| Correlación de Eventos y Gestión de Alertas de Seguridad                                     | 34 |
| Propuesta de Indicadores Clave de Seguridad (KPIs y KRIs)                                    | 35 |
| <b>PLAN DE RESPUESTA A INCIDENTES Y CONTINUIDAD DEL NEGOCIO (BCP/DRP)</b>                    | 37 |
| Definición y Clasificación de Incidentes de Ciberseguridad                                   | 37 |
| <b>Roles y Responsabilidades del Comité de Crisis y Equipo de Respuesta (CSIRT)</b>          | 38 |
| <b>Protocolos de Contención, Erradicación y Recuperación</b>                                 | 39 |
| <b>Protocolo ante Ataques de Ransomware (Secuestro de Renders y Planos)</b>                  | 41 |
| Procedimiento de respuesta                                                                   | 41 |
| Protocolo ante Fuga de Datos de la Cartera de Clientes                                       | 41 |
| Política y Estrategia de Respallos (Backup) Inmutables y Regla 3-2-1                         | 42 |
| Plan de Continuidad del Negocio (BCP) para Operaciones en San Miguel                         | 43 |
| <b>Plan de capacitación de usuarios</b>                                                      | 45 |
| Tabla de planificación                                                                       | 46 |
| <b>Evaluación de Madurez de Controles de Seguridad</b>                                       | 47 |
| <b>Evaluación de Cumplimiento Normativo</b>                                                  | 48 |
| <b>Recomendaciones Estratégicas</b>                                                          | 49 |
| <b>Hoja de Ruta (Roadmap de Implementación)</b>                                              | 50 |
| <b>Conclusión</b>                                                                            | 51 |
| Importancia del documento                                                                    | 51 |
| <b>Anexos Técnicos</b>                                                                       | 52 |
| A. Matriz de Activos de la Información                                                       | 52 |

|                           |                                                                  |           |
|---------------------------|------------------------------------------------------------------|-----------|
| B.                        | Evaluación de riesgos .....                                      | 52        |
| C.                        | Matriz de riesgos .....                                          | 53        |
| D.                        | Evaluación de Madurez de Ciberseguridad .....                    | 54        |
| E.                        | Amenazas y mitigaciones según fases .....                        | 55        |
| F.                        | Diagrama arquitectura de red .....                               | 56        |
| G.                        | KPIs y KRIs de Seguridad .....                                   | 56        |
| H.                        | Definición y Clasificación de Incidentes de Ciberseguridad ..... | 57        |
| I.                        | Tabla de planificación .....                                     | 58        |
| J.                        | Evaluación de Madurez de Controles de Seguridad .....            | 58        |
| <b>Glosario .....</b>     |                                                                  | <b>59</b> |
| <b>Bibliografía .....</b> |                                                                  | <b>61</b> |

## Resumen Ejecutivo

El presente informe técnico-ejecutivo recopila los resultados de la evaluación integral de ciberseguridad realizada sobre la infraestructura digital, almacenamiento lógico y redes de comunicación de Construservices. El objetivo central consiste en blindar los activos intangibles estratégicos (planos de ingeniería, modelados 3D y bases de datos transaccionales) procesados en el centro operativo de San Miguel ante vectores de amenazas modernos como Ransomware, Inyecciones de Código y movimientos laterales no autorizados.

### Métricas Clave de la Postura de Seguridad

La siguiente matriz resume cuantitativamente el estado actual detectado en los activos e infraestructura críticos evaluados:

| Dominio de Control          | Estado Inicial                              | Nivel de Riesgo | Acción Correctiva Prioritaria                          |
|-----------------------------|---------------------------------------------|-----------------|--------------------------------------------------------|
| Perímetro de Red            | Estructura plana, sin segmentación          | <b>Crítico</b>  | Despliegue de NGFW y segmentación física/lógica VLAN.  |
| Almacenamiento de Archivos  | Carga libre de renders/planos (.dwg)        | <b>Alto</b>     | Validación estricta de tipos MIME y hashes únicos.     |
| Control de Accesos          | Autenticación basada en contraseñas simples | <b>Alto</b>     | Implementación obligatoria de MFA y protocolo 802.1X.  |
| Continuidad del Negocio     | Respaldos manuales locales desorganizados   | <b>Medio</b>    | Automatización de respaldos bajo esquema formal 3-2-1. |
| Gestión de Vulnerabilidades | Ausencia de parches y auditorías TI         | <b>Alto</b>     | Configuración de sistema SIEM y agentes EDR/XDR.       |

## Introducción y contexto organizacional

### Perfil de la empresa

Construservices es una empresa dedicada al sector de la construcción a nivel nacional, con participación en proyectos de gran impacto para el desarrollo y la urbanización del país. Entre sus principales áreas de trabajo se encuentran la construcción de centros comerciales, residenciales privadas, carreteras, edificios corporativos y diversas infraestructuras destinadas a operaciones empresariales y comerciales.

Gracias a su crecimiento y participación en proyectos de gran escala, la empresa ha incorporado diferentes herramientas tecnológicas para optimizar sus procesos administrativos, operativos y de planificación. Esto le ha permitido mejorar la gestión de proyectos, el control de recursos y la comunicación con clientes y empleados.

El centro operativo de Construservices se encuentra ubicado en la zona oriental del país, específicamente en la ciudad de San Miguel. En estas instalaciones se desarrolla gran parte de la logística y administración de la empresa, contando con equipos informáticos de alta capacidad de procesamiento utilizados para renderizados arquitectónicos, elaboración de planos digitales y modelados en 3D para proyectos de construcción.

Además, la empresa dispone de un sistema interno mediante el cual se gestionan usuarios, tanto empleados como clientes. A través de esta plataforma se realizan cotizaciones de proyectos, seguimiento de avances de obra, envío de documentación y archivos técnicos, así como la administración de información relacionada con clientes y contratos. Debido a la naturaleza de estos datos, gran parte de la información manejada por la empresa es considerada sensible y requiere mecanismos adecuados de protección y control de acceso.

Asimismo, Construservices cuenta con un sistema para la gestión de maquinaria, vehículos y herramientas de trabajo. Este sistema permite asignar equipos a empleados específicos, controlar los tiempos de uso, registrar mantenimientos preventivos y correctivos, así como llevar un monitoreo general del estado operativo de cada recurso utilizado en los distintos proyectos de construcción.

Debido a la dependencia tecnológica de la empresa y a la cantidad de información crítica que administra diariamente, resulta fundamental implementar medidas de ciberseguridad que permitan proteger los sistemas, prevenir accesos no autorizados y garantizar la integridad, disponibilidad y confidencialidad de la información corporativa.

### Alcance del análisis de ciberseguridad

En este documento se realizará un análisis de ciberseguridad con el objetivo de identificar y evaluar las posibles vulnerabilidades presentes en la infraestructura tecnológica de la empresa, buscando reducir riesgos y amenazas que puedan comprometer la seguridad de la información, la continuidad operativa y la integridad de los sistemas utilizados dentro de la organización.

El análisis abarcará los equipos informáticos, servidores, redes internas, sistemas de gestión, almacenamiento de información y plataformas utilizadas por la empresa para sus operaciones diarias. Asimismo, se evaluarán los mecanismos de control de acceso, la protección de datos sensibles y las políticas de seguridad implementadas actualmente.

De igual manera, se propondrán medidas para reforzar los sistemas de ciberseguridad, tales como la implementación de subredes cuando sea necesario, el uso de firewalls, segmentación de red, controles de acceso, copias de seguridad y la incorporación de herramientas para el monitoreo y detección de amenazas informáticas.

Además, se buscará establecer buenas prácticas de seguridad que permitan prevenir incidentes cibernéticos, minimizar el impacto de posibles ataques y fortalecer la protección de la información tanto de la empresa como de sus clientes y empleados.

## Objetivos

### Objetivo general

Desarrollar un análisis integral de la postura de ciberseguridad de la empresa **Construservices** mediante la identificación, evaluación y catalogación de sus vulnerabilidades, riesgos y amenazas potenciales, con el fin de diseñar un plan estratégico de mitigación técnica y operativa que fortalezca la infraestructura tecnológica, garantice la continuidad del negocio y salvaguarde la confidencialidad, integridad y disponibilidad de sus activos críticos de información.

### Objetivos específicos

1. **Clasificar y valorar los activos de información** tangibles e intangibles de Construservices, priorizando la infraestructura de cómputo de alto rendimiento en San Miguel, los planos de ingeniería, los renders 3D y las bases de datos con información sensible de clientes.
2. **Identificar y mapear las amenazas y vulnerabilidades** existentes en la red perimetral y en los sistemas internos de gestión (clientes, cotizaciones y maquinaria), utilizando como referencia marcos globales como el *NIST Cybersecurity Framework* y la matriz *MITRE ATT&CK*.
3. **Diseñar una arquitectura de red segura y segmentada** mediante la implementación de subredes lógicas (VLANs), restringiendo el tráfico no autorizado entre las áreas administrativas, de ingeniería y de acceso público o invitados.
4. **Formular un plan de respuesta a incidentes y monitoreo continuo** que defina protocolos claros de contención ante incidentes de alto impacto (como infecciones por *ransomware* o fugas de información) y proponga herramientas de detección temprana de anomalías informáticas.

## Marcos de referencia y estándares utilizados

**ISO/IEC 27001:** es la norma más conocida del mundo para sistemas de gestión de la seguridad de la información (SGSI). Esta norma define los requisitos que debe cumplir un SGSI, proporciona a las empresas de cualquier tamaño y de todos los sectores orientaciones para establecer, implantar, mantener y mejorar de manera continua un sistema de gestión de la seguridad de la información.

(ISO, s.f.)

**NIST CSF:** El marco de ciberseguridad del NIST (NIST CSF) proporciona orientación integral y mejores prácticas que las organizaciones del sector privado pueden seguir para mejorar la seguridad de la información y la gestión de riesgos de ciberseguridad.

El Instituto Nacional de Estándares y Tecnología (NIST) de EE. UU. es una agencia no reguladora que promueve la innovación mediante el avance de la ciencia de medición, los estándares y la tecnología.

(IBM, s.f.)

**TIA/EIA-568:** es una norma de cableado estructurado que establece los requisitos y procedimientos para el diseño, instalación y mantenimiento de sistemas de cableado de redes de telecomunicaciones en edificios comerciales y residenciales. Esta norma define los estándares de cableado para la transmisión de voz, datos y vídeo. La implementación adecuada de la norma TIA/EIA 568 es esencial para garantizar la eficiencia y la calidad de la red de telecomunicaciones. En este artículo, se explicará más acerca de qué significa TIA EIA 568 y su importancia en la industria de las telecomunicaciones.

**MITRE ATT&CK:** es una base de conocimiento globalmente accesible sobre tácticas y técnicas de adversario basada en observaciones del mundo real. La base de conocimiento de ATT&CK se utiliza como base para el desarrollo de modelos y metodologías específicas de amenazas en el sector privado, en el gobierno y en la comunidad de productos y servicios de ciberseguridad.

(mitre, s.f.)

## Inventarió de activos de información

### Clasificación y Valoración de Activos de la información

En este apartado de identificaron los activos de la información existentes dentro de la empresa, posterior a eso se realiza la matriz de activos.

**Base de datos (DB):** La base de datos es una activo muy crítico porque de ella depende toda la información de la organización y del sistema como tal, dentro de las bases de datos podemos encontrar información personal de empleados, registro de clientes, reportes, historiales e información sobre proyectos, transacciones y ventas realizadas.

**Aplicaciones:** Dentro del activo de aplicaciones se puede encontrar el sistema para la gestión de empleados y clientes el cual es de vital importancia para la infraestructura tecnológica de la empresa puesto que con este sistema se realizan muchas operaciones internas, de igual manera se encuentra el sistema para la gestión de maquinaria y equipo de construcción.

**información financiera:** La información financiera es un activo critico debido a la información sensible que se maneja como pueden ser cuentas bancarias, historial de pagos, historial de préstamos, datos de socios, datos de clientes y empleados.

### Matriz de Activos de la Información

| ID | Activo                  | Tipo de Activo        | Descripción                                                                                          | Importancia | Información que contiene                                                                | Nivel de criticidad |
|----|-------------------------|-----------------------|------------------------------------------------------------------------------------------------------|-------------|-----------------------------------------------------------------------------------------|---------------------|
| 1  | Base de datos           | Información /Software | Sistema encargado de almacenar toda la información crítica de la empresa y de los sistemas internos. | Muy Alta    | Datos de empleados, clientes, reportes, historiales, proyectos, ventas y transacciones. | Crítico             |
| 2  | Aplicaciones de Gestión | Software              | Sistemas utilizados para la administración de empleados, clientes y maquinaria de construcción.      | Alta        | Información operativa, registros administrativos y control de maquinaria                | Alto                |
| 3  | Información Financiera  | Información           | Información económica y                                                                              | Muy Alta    | Cuentas bancarias,                                                                      | Crítico             |

|                                                                                  |                                                            |
|----------------------------------------------------------------------------------|------------------------------------------------------------|
| financiera de la empresa utilizada para operaciones administrativas y contables. | historial de pagos, datos de socios, clientes y empleados. |
|----------------------------------------------------------------------------------|------------------------------------------------------------|

## Activos de Hardware

**Servidores y computadoras con alto de procesamiento:** La empresa cuenta con computadoras y servidores de alto rendimiento que son fundamentales para el desarrollo de las operaciones diarias, especialmente en tareas de renderizado, modelado 3D y elaboración de planos. Estos equipos permiten ejecutar software especializado utilizado en proyectos de construcción e ingeniería.

Asimismo, la organización dispone de servidores dedicados al almacenamiento y gestión de información crítica, donde se resguardan archivos de proyectos, registros históricos, documentación técnica y demás información generada desde el inicio de las operaciones de la empresa. Debido a la importancia y sensibilidad de esta información, los activos de hardware son considerados recursos críticos que requieren medidas adecuadas de protección y mantenimiento.

**Infraestructura de red:** La infraestructura de red representa un activo fundamental para el funcionamiento de la empresa, ya que permite la comunicación y transferencia de información entre los diferentes sistemas, dispositivos y usuarios de la organización. Debido al tipo de operaciones que realiza la empresa, se requiere una conexión de alta velocidad y estabilidad para la transferencia eficiente de archivos de gran tamaño, como planos, diseños, modelos 3D y documentación técnica relacionada con los proyectos.

Asimismo, la red corporativa debe ser capaz de soportar múltiples usuarios y dispositivos conectados simultáneamente dentro del centro de operaciones, garantizando la disponibilidad de los servicios y el acceso continuo a los recursos tecnológicos. Por la importancia de mantener la continuidad operativa y el flujo de información, la infraestructura de red es considerada un activo crítico dentro de la organización.

**Endpoints:** Los endpoints son todos los dispositivos finales que están en la organización, se considera un activo debido a que son recursos que tiene valor para la organización y que por lo tanto deben protegerse, los endpoints más comunes a mencionar son computadoras de trabajadores, servidores y dispositivos móviles.

## Identificación de Usuarios y Roles

Dentro del sistema de administración de operaciones se encuentran los siguientes usuarios y roles.

**Super Administradores:** es el rol de más alto rango y tienen acceso a todos los módulos del sistema en los cuales pueden realizar acciones de crear, editar y eliminar.

**Administradores de área:** son usuarios encargados de administrar un área en específico como lo pueden ser finanzas, clientes, usuarios empleados etc.

**Encargados de proyectos:** estos usuarios administran los proyectos activos, pueden ver archivos y editarlos además de tener comunicación directa con clientes y poder tomar decisiones fundamentales.

**Empleados diseñadores y colaboradores de proyectos:** estos usuarios son los que realizan diseños y suben constantemente cargas de archivos para avanzar con los proyectos pendientes.

Dentro del sistema de maquinaria se encuentran los siguientes usuarios y roles:

- **Administradores generales:** son los encargados de gestionar y tener el control de todos los módulos del sistema
- **Supervisores:** se encargan de asignar los equipos a los operadores
- **Operadores:** se encargan de manipular los equipos y cumplir con los trabajos asignados.

# ANÁLISIS Y EVALUACIÓN DE RIESGOS

Según la norma ISO/IEC 27001

Metodología de evaluación de riesgos

Para la realización del análisis de riesgos se utilizó como referencia la metodología propuesta por la norma ISO/IEC 27001, la cual permite identificar, analizar y tratar los riesgos relacionados con la seguridad de la información dentro de la organización.

La evaluación se desarrolló mediante las siguientes etapas:

1. Identificación de activos críticos de información.
2. Identificación de amenazas y vulnerabilidades asociadas.
3. Evaluación del impacto potencial sobre la confidencialidad, integridad y disponibilidad de la información.
4. Determinación de la probabilidad de ocurrencia de los riesgos.
5. Clasificación del nivel de riesgo.
6. Propuesta de controles y medidas de mitigación.



La valoración del riesgo se realizó tomando en consideración el impacto operativo, financiero y reputacional que un incidente de seguridad podría ocasionar a la empresa Construservices.

### *Identificación de amenazas*

Entre las principales amenazas identificadas para la infraestructura tecnológica de Construservices se encuentran:

- Ataques de ransomware dirigidos a servidores y estaciones de trabajo.
- Robo o fuga de información confidencial de clientes.
- Accesos no autorizados a los sistemas internos.
- Phishing e ingeniería social contra empleados.
- Malware en equipos utilizados para renderizado y diseño.
- Fallas en servidores o interrupciones de red.
- Pérdida de información por errores humanos.
- Uso indebido de privilegios administrativos.
- Ataques a la infraestructura web y sistemas internos.
- Daños físicos a equipos tecnológicos.

### *Identificación de vulnerabilidades*

Las vulnerabilidades detectadas dentro de la organización incluyen:

- Falta de segmentación de red.
- Ausencia de autenticación multifactor (MFA).
- Contraseñas débiles o reutilizadas.
- Falta de políticas formales de ciberseguridad.
- Escaso monitoreo de eventos de seguridad.
- Ausencia de capacitación constante al personal.
- Sistemas y software desactualizados.
- Deficiencias en respaldos y recuperación de información.

- Exposición de sistemas internos a internet.
- Falta de controles de acceso basados en roles.

| <i><b>Vulnerabilidad</b></i>        | <i><b>Críticidad</b></i> |
|-------------------------------------|--------------------------|
| <i>Falta de segmentación de red</i> | <b>Crítica</b>           |
| <i>Ausencia de MFA</i>              | <b>Crítica</b>           |
| <i>Contraseñas débiles</i>          | <b>Alta</b>              |
| <i>Escaso monitoreo</i>             | <b>Alta</b>              |
| <i>Sistemas desactualizados</i>     | <b>Alta</b>              |
| <i>Deficiencias en respaldos</i>    | <b>Alta</b>              |
| <i>Falta de capacitación</i>        | <b>Media</b>             |
| <i>Falta de RBAC</i>                | <b>Media</b>             |

### Matriz de probabilidad e impacto

La evaluación de riesgos se realizó utilizando una matriz basada en dos factores:

#### Probabilidad

- Baja
- Media
- Alta

#### Impacto

- Bajo
- Medio
- Alto
- Crítico

El nivel de riesgo se determinó combinando ambos factores para priorizar las amenazas que requieren atención inmediata.

## Matriz de riesgos

| <b>Riesgo</b>                            | <b>Probabilidad</b> | <b>Impacto</b> | <b>Nivel de Riesgo</b> |
|------------------------------------------|---------------------|----------------|------------------------|
| <b>Ransomware en servidores</b>          | <b>Alta</b>         | <b>Crítico</b> | <b>Crítico</b>         |
| <b>Fuga de información de clientes</b>   | <b>Media</b>        | <b>Crítico</b> | <b>Alto</b>            |
| <b>Acceso no autorizado</b>              | <b>Alta</b>         | <b>Alto</b>    | <b>Alto</b>            |
| <b>Pérdida de información por fallas</b> | <b>Media</b>        | <b>Alto</b>    | <b>Alto</b>            |
| <b>Phishing a empleados</b>              | <b>Alta</b>         | <b>Medio</b>   | <b>Alto</b>            |
| <b>Caída de la red corporativa</b>       | <b>Media</b>        | <b>Alto</b>    | <b>Alto</b>            |
| <b>Malware en estaciones de trabajo</b>  | <b>Alta</b>         | <b>Medio</b>   | <b>Alto</b>            |

## Riesgo residual

Luego de aplicar controles de seguridad como firewalls, segmentación de red, copias de seguridad, autenticación multifactor y monitoreo continuo, el nivel de riesgo residual esperado disminuirá considerablemente, permitiendo que la empresa mantenga un nivel de riesgo aceptable para sus operaciones.

## Controles recomendados

Como parte del tratamiento de riesgos se recomienda implementar los siguientes controles:

- Segmentación de red mediante VLANs.
- Implementación de firewalls de nueva generación (NGFW).
- Uso obligatorio de MFA.
- Políticas de contraseñas seguras.
- Sistemas EDR/XDR para detección de amenazas.

- Respaldo bajo la regla 3-2-1.
- Capacitación constante contra phishing.
- Monitoreo SIEM.
- Gestión de privilegios y accesos.
- Actualización y parcheo continuo de sistemas.

## Justificación del SIEM y EDR/XDR

La implementación de una plataforma SIEM permitirá centralizar eventos de seguridad y detectar amenazas en tiempo real. Asimismo, las soluciones EDR/XDR fortalecerán la capacidad de monitoreo, análisis y respuesta ante incidentes avanzados, reduciendo significativamente el tiempo de detección y contención.

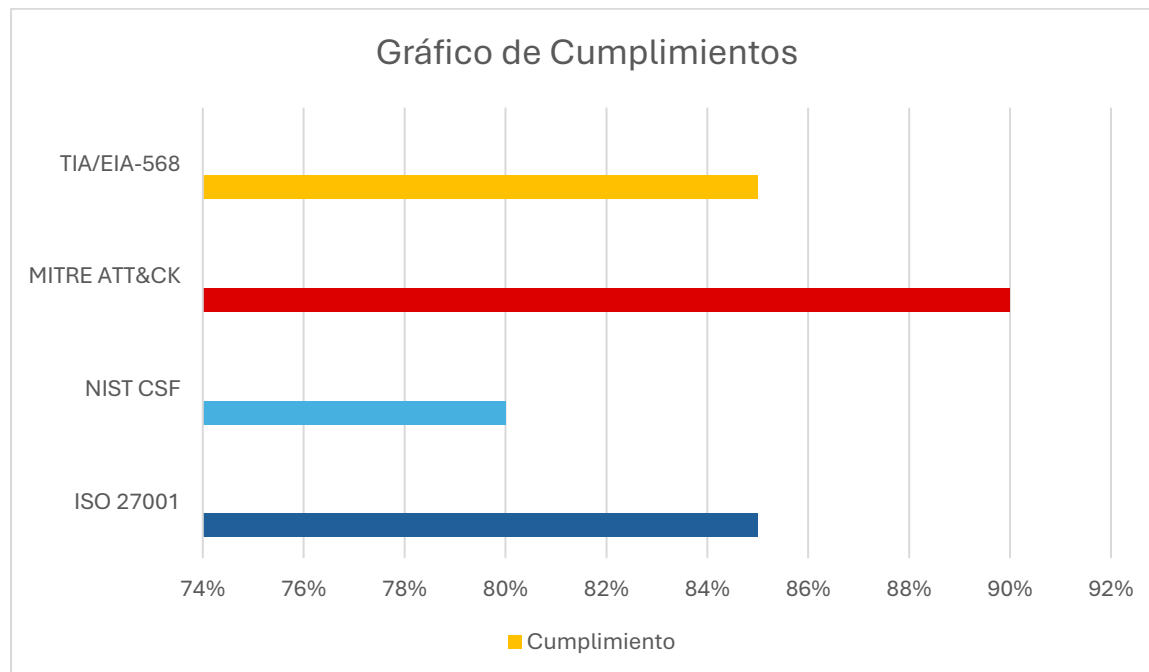
## Evaluación de Madurez de Ciberseguridad

| DOMINIO            | NIVEL |
|--------------------|-------|
| GOBERNANZA         | 3     |
| GESTIÓN DE RIESGOS | 4     |
| PROTECCIÓN         | 3     |
| DETECCIÓN          | 2     |
| RESPUESTA          | 3     |
| RECUPERACIÓN       | 4     |

La evaluación de madurez se realizó utilizando una escala de 1 a 5, donde 1 representa un nivel inicial y 5 un nivel optimizado. Los resultados muestran que Construservices posee una madurez intermedia en ciberseguridad. La gestión de riesgos y la recuperación presentan los niveles más altos debido a la existencia de controles y planes definidos, mientras que la detección presenta un nivel menor por la falta de herramientas implementadas para el monitoreo continuo. En general, la organización cuenta con una base adecuada de seguridad, pero requiere fortalecer sus capacidades de protección y detección para mejorar su postura de ciberseguridad.

*Cumplimiento de Marcos*

| Estándar     | Cumplimiento |
|--------------|--------------|
| ISO 27001    | 85%          |
| NIST CSF     | 80%          |
| MITRE ATT&CK | 90%          |
| TIA/EIA-568  | 85%          |



## Mapecto de amenazas mediante el marco MITRE ATT&CK

MITRE ATT&CK (Adversarial Tactics, Techniques and Common Knowledge) es una base de conocimiento ampliamente reconocida a nivel mundial que recopila tácticas, técnicas y procedimientos (TTPs) utilizados por actores maliciosos en escenarios reales de ciberataques. Este marco proporciona una referencia estructurada para comprender cómo operan los adversarios durante las distintas fases de un ataque, desde el acceso inicial hasta el impacto final sobre los sistemas comprometidos.

La matriz ATT&CK es utilizada por organizaciones públicas y privadas, equipos de respuesta a incidentes, analistas de seguridad y fabricantes de soluciones tecnológicas para fortalecer sus capacidades de prevención, detección y respuesta ante amenazas cibernéticas. Gracias a su enfoque basado en evidencia y observaciones del mundo real, se ha convertido en uno de los marcos de referencia más importantes para la gestión de la ciberseguridad a nivel internacional.

A través del desarrollo de ATT&CK, MITRE contribuye al fortalecimiento de la seguridad digital global, proporcionando una plataforma abierta y accesible que permite a las organizaciones evaluar su postura de seguridad, identificar posibles vectores de ataque y diseñar controles de protección más efectivos. Su disponibilidad pública facilita la adopción de buenas prácticas y promueve la colaboración entre los diferentes sectores involucrados en la protección de la información.

(Mitre, s.f.)

En el presente análisis se ha realizado un mapeo de las amenazas identificadas para Construservices utilizando el marco MITRE ATT&CK, con el objetivo de relacionar los riesgos detectados con las tácticas y técnicas que podrían ser empleadas por un atacante para comprometer los activos críticos de la organización. Este ejercicio permite comprender de manera más precisa los posibles escenarios de ataque a los que se enfrenta la empresa y evaluar el nivel de exposición de sus sistemas, redes y datos sensibles.

La siguiente figura muestra la matriz de mapeo elaborada a partir de las amenazas registradas durante la evaluación, así como las amenazas potenciales que podrían afectar a la organización en función de su infraestructura tecnológica, procesos de negocio y superficie de ataque identificada.

Asimismo, cada técnica identificada dentro del marco MITRE ATT&CK se encuentra asociada a controles y medidas de mitigación específicas, las cuales sirven como referencia para la implementación de estrategias de protección, monitoreo y respuesta. Esto permite establecer un vínculo directo entre los riesgos detectados y las acciones de seguridad recomendadas, facilitando la priorización de controles y el fortalecimiento continuo de la postura de ciberseguridad de la empresa.

| Capa X                                                                 |                                                    |                                              |                                                  |                                                      |                                                         |                                                    |                                                                     |                                                               |                                                               |                                                       |                                             |                                                |                                                      |                                                 |
|------------------------------------------------------------------------|----------------------------------------------------|----------------------------------------------|--------------------------------------------------|------------------------------------------------------|---------------------------------------------------------|----------------------------------------------------|---------------------------------------------------------------------|---------------------------------------------------------------|---------------------------------------------------------------|-------------------------------------------------------|---------------------------------------------|------------------------------------------------|------------------------------------------------------|-------------------------------------------------|
| <div>Controles de selecciónControles de capaControles de técnica</div> |                                                    |                                              |                                                  |                                                      |                                                         |                                                    |                                                                     |                                                               |                                                               |                                                       |                                             |                                                |                                                      |                                                 |
| <div>T🔍🗨🔗🔧🔧🔧🔧🔧🔧🔧🔧🔧🔧🔧🔧</div>                                            |                                                    |                                              |                                                  |                                                      |                                                         |                                                    |                                                                     |                                                               |                                                               |                                                       |                                             |                                                |                                                      |                                                 |
| Reconocimiento                                                         | Desarrollo de recursos                             | Acceso inicial                               | Ejecución                                        | Persistencia                                         | Escalada de privilegios                                 | Sigilo                                             | Discapacidad de defensa                                             | Acceso a credenciales                                         | Descubrimiento                                                | Movimiento lateral                                    | Colección                                   | Mando y Control                                | Exfiltración                                         | Impacto                                         |
| 12 técnicas                                                            | 9 técnicas                                         | 11 técnicas                                  | 20 técnicas                                      | 22 técnicas                                          | 13 técnicas                                             | 30 técnicas                                        | 16 técnicas                                                         | 17 técnicas                                                   | 34 técnicas                                                   | 9 técnicas                                            | 17 técnicas                                 | 18 técnicas                                    | 9 técnicas                                           | 15 técnicas                                     |
| Escaneo activo (0.01)                                                  | Adquisición de acceso (0.01)                       | Inyección de contenido (0.01)                | Empleos en BITS (0.01)                           | Manipulación de contenido (0.01)                     | Mecanismo de control de elevación por token (0.01)      | Manipulación de Token de Acceso (0.01)             | Desactivar o modificar el cortafuegos del sistema (0.01)            | Adversario en el Medio (0.01)                                 | Descubrimiento de cuentas (0.01)                              | Explotación de servicios remotos (0.01)               | Adversario en el Medio (0.01)               | Protocolo de Capa de Comunicación (0.01)       | Exfiltración automatizada (0.01)                     | Eliminación de acceso a cuentas (0.01)          |
| Recopila información sobre el antivirus de las víctimas (0.01)         | Adquisición de credenciales por paso rápido (0.01) | Compromiso de paso rápido (0.01)             | Mando de Administración de la Nube (0.01)        | Empleos en BITS (0.01)                               | Manipulación de Token de Acceso (0.01)                  | Empleos en BITS (0.01)                             | Desactivar o modificar el cortafuegos del sistema (0.01)            | Fuerza bruta (0.01)                                           | Descubrimiento de la ventana de aplicación (0.01)             | Spearphishing interno (0.01)                          | Datos recopilados en el archivo (0.01)      | Datos recopilados en el archivo (0.01)         | Límites de tamaño de transferencia de datos (0.01)   | Destrucción de datos (0.01)                     |
| Recopila información de identidad de la víctima (0.01)                 | Cuentas de compromiso (0.01)                       | Explotar Aplicación Javascript (0.01)        | Integrita de compromisos y scripts (0.01)        | Ejecución automática de compromisos y scripts (0.01) | Manipulación de Token de Acceso (0.01)                  | Explotación de depuradores (0.01)                  | Desactivar o modificar el cortafuegos del sistema (0.01)            | Credenciales de Almacenes de contraseñas (0.01)               | Descubrimiento de información del navegador (0.01)            | Transferencia lateral de herramientas (0.01)          | Captura de audio (0.01)                     | Recolección Automatizada (0.01)                | Exfiltración sobre protocolo alternativo (0.01)      | Datos cifrados para el impacto (0.01)           |
| Recopila información sobre la Red de Víctimas (0.01)                   | Desarrollar capacidades de compromiso (0.01)       | Servicios Remotos Externos (0.01)            | Incorporaciones de Contenedores (0.01)           | Scripts de arranque o inicio de sesión (0.01)        | Manipulación de cuentas (0.01)                          | Ejecución con retraso (0.01)                       | Desusar/Definición de archivos o información (0.01)                 | Acción para el acceso a credenciales (0.01)                   | Descubrimiento de infraestructura en la nube (0.01)           | Suicidio de sesiones de servicio remoto (0.01)        | Suicidio de sesiones de navegador (0.01)    | Codificación de datos (0.01)                   | Exfiltración sobre el canal C2 (0.01)                | Desfiguración (0.01)                            |
| Recopila información sobre la Red de Víctimas (0.01)                   | Establecer cuentas (0.01)                          | Phishing (0.01)                              | Contenedor de despliegue (0.01)                  | Integración de aplicaciones en la nube (0.01)        | Scripts de arranque o inicio de sesión (0.01)           | Medidas de seguridad para la ejecución (0.01)      | Acción directa a volúmenes (0.01)                                   | Autenticación forzada (0.01)                                  | Panel de Servicios en la Nube (0.01)                          | Servicios Remotos (0.01)                              | Datos del portapapeles (0.01)               | Resolución de datos (0.01)                     | Exfiltración sobre otro medio de red (0.01)          | Borrado de disco (0.01)                         |
| Recopila información sobre la Organización de Víctimas (0.01)          | Generar contenido (0.01)                           | Reemplazar mediante medios extraíbles (0.01) | Mando de Administración ESKI (0.01)              | Compromiso binario de software antiántrax (0.01)     | Scripts de arranque o inicio de sesión (0.01)           | Explotación para el sigilo (0.01)                  | Modificación de permisos de archivos y directorios (0.01)           | Credenciales web de Forge (0.01)                              | Descubrimiento de servicios en la nube (0.01)                 | Replicación mediante medios extraíbles (0.01)         | Datos de almacenamiento en la nube (0.01)   | Datos de almacenamiento en la nube (0.01)      | Canal cifrado (0.01)                                 | Corrupción de Servicio en el punto final (0.01) |
| Phishing para obtener información (0.01)                               | Obtener capacidades (0.01)                         | Compromiso en la cadena de suministro (0.01) | Explotación para la ejecución del cliente (0.01) | Crear cuenta (0.01)                                  | Crear o modificar el proceso del sistema (0.01)         | Flujo de ejecución de secuencias (0.01)            | Modificación del proceso de autenticación (0.01)                    | Captura de entrada (0.01)                                     | Descubrimiento de objetos en almacenamiento en la nube (0.01) | Herramientas de despliegue de software (0.01)         | Datos del Registro de Configuración (0.01)  | Quitar infraestructuras (0.01)                 | Exfiltración a través de servicios web (0.01)        | Robo financiero (0.01)                          |
| Consulta a Servicios Públicos de la víctima (0.01)                     | Capacidades de la capa (0.01)                      | Relación de confianza (0.01)                 | Flujo de ejecución de confianza (0.01)           | Crear o modificar el proceso del sistema (0.01)      | Modificación de políticas de proceso o inquilino (0.01) | Eliminación de indicadores (0.01)                  | Modificación del proceso de autenticación (0.01)                    | Interrupción de autenticación multifactor (0.01)              | Descubrimiento de controladores de dispositivos (0.01)        | Contenido compartido de contaminación (0.01)          | Datos de Repositorios de Información (0.01) | Transferencia de Información de Ingreso (0.01) | Transferencia programada (0.01)                      | Denegación de Servicio de Red (0.01)            |
| Bucar fuentes cerradas (0.01)                                          | Cuentas válidas (0.01)                             | Inyección de entrada (0.01)                  | Ejecución de entrada (0.01)                      | Control Exclusivo (0.01)                             | Eventos de Servicio Remoto Externos (0.01)              | Escape al antiántrax (0.01)                        | Modificación de la infraestructura de computación en la nube (0.01) | Generación de solicitudes de autenticación multifactor (0.01) | Descubrimiento de archivos y directorios (0.01)               | Utilizar material alternativo de autenticación (0.01) | Datos de la unidad compartida de red (0.01) | Canales de vanias etapas (0.01)                | Transferencia de datos a la cuenta en la nube (0.01) | Secuestro de recursos (0.01)                    |
| Bucar en bases de datos técnicas abiertas (0.01)                       | Redes Wi-Fi (0.01)                                 | Comunicación entre procesos (0.01)           | Comunicación entre procesos (0.01)               | Control Exclusivo (0.01)                             | Explotación para la escalada de privilegios (0.01)      | Ejecución indirecta de mandos (0.01)               | Modificación de la jerarquía de recursos en la nube (0.01)          | Ofilato de la red (0.01)                                      | Descubrimiento de la Póliza de Grupo (0.01)                   | Enciframientos de datos (0.01)                        | Datos de medios extraíbles (0.01)           | Protocolo de Capa de Aplicación (0.01)         | Parada de servicio (0.01)                            | Apagado/Reinicio del sistema (0.01)             |
| Bucar sitios web/dominios abiertos (0.01)                              | API nativa (0.01)                                  | Ejecución de Pipeline Envenenada (0.01)      | Ejecución de Pipeline Envenenada (0.01)          | Control Exclusivo (0.01)                             | Explotación para la escalada de privilegios (0.01)      | Explotación para la escalada de privilegios (0.01) | Modificación del registro (0.01)                                    | Verdido de credenciales del sistema operativo (0.01)          | Descubrimiento de almacenamiento local (0.01)                 | Coolección de correos electrónicos (0.01)             | Colección de correos electrónicos (0.01)    | Proxy (0.01)                                   |                                                      |                                                 |
| Datos de Proveedores de Riesgo (0.01)                                  | Tarea/Trabajo Programado (0.01)                    | Modificación del registro (0.01)             | Modificación del registro (0.01)                 | Control Exclusivo (0.01)                             | Explotación para la escalada de privilegios (0.01)      | Explotación para la escalada de privilegios (0.01) | Modificación de la imagen del sistema (0.01)                        | Robar el token de acceso a la aplicación (0.01)               | Enumeración de logs (0.01)                                    | Captura de logs (0.01)                                | Captura de logs (0.01)                      | Herramientas de acceso remoto (0.01)           |                                                      |                                                 |
| Bucar en sitios web propiedad de víctimas (0.01)                       | Módulos compartidos (0.01)                         | Inicio de aplicaciones de oficina (0.01)     | Inicio de aplicaciones de oficina (0.01)         | Control Exclusivo (0.01)                             | Explotación para la escalada de privilegios (0.01)      | Explotación para la escalada de privilegios (0.01) | Cuentas válidas (0.01)                                              | Puente de Límites de Red (0.01)                               | Descubrimiento de servicios de red (0.01)                     | Captura de pantalla (0.01)                            | Captura de pantalla (0.01)                  |                                                |                                                      |                                                 |

Leyenda

## Amenazas y mitigaciones según fases

### Fase de reconocimiento

| Amenaza                                  | Mitigación                                                                                                                                                                                                                                                                                       |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Escaneo activo</b>                    | Esta técnica no puede mitigarse fácilmente con controles preventivos, ya que se basa en comportamientos realizados fuera del alcance de las defensas y controles empresariales. Los esfuerzos deberían centrarse en minimizar la cantidad y sensibilidad de los datos disponibles para terceros. |
| <b>Adquisición de acceso</b>             | Esta técnica no puede mitigarse fácilmente con controles preventivos, ya que se basa en comportamientos realizados fuera del alcance de las defensas y controles empresariales.                                                                                                                  |
| <b>Phishing para obtener información</b> | Se puede entrenar a los usuarios para identificar técnicas de ingeniería social e intentos de spearphishing                                                                                                                                                                                      |

### Fase de Acceso inicial

| Amenaza                            | Mitigación                                                                                                                                                                                                                                                                                                               |
|------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Inyección de contenido</b>      | Detectar creaciones de archivos sospechosas y ejecutar procesos desencadenados por actividad del navegador (por ejemplo, cargas útiles inyectadas escritas en directorios %appdata% o Temp, y luego ejecutadas). Correlacionar anomalías de red con la creación local de procesos o la ejecución de scripts posteriores. |
| <b>Incorporaciones de hardware</b> | Bloquea dispositivos y accesorios desconocidos mediante la configuración y el agente de monitorización de seguridad de endpoint.                                                                                                                                                                                         |
| <b>Redes wi-fi</b>                 | La segmentación de red puede utilizarse para aislar componentes de infraestructura que no requieren acceso amplio a la red. Entornos de red separados para redes wi-fi y cableadas por ethernet, especialmente donde las redes basadas en ethernet permiten el acceso a recursos sensibles                               |

|                                                           |                                                                                                                                                                                                                                              |
|-----------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Intérprete de comandos y scripts</b>                   | Evitar la instalación por parte del usuario de intérpretes de comandos y scripts no necesarios.                                                                                                                                              |
| <b>Modificación de permisos de archivos y directorios</b> | Aplicar permisos más restrictivos a archivos y directorios podría evitar que los adversarios modifiquen sus listas de control de acceso.                                                                                                     |
| <b>Ingeniería social</b>                                  | Detecta concesiones de consentimiento, restablecimiento de contraseñas, cambios de rol, compartición externa o creación de tokens poco después de la interacción de usuario con mensajes, invitaciones o flujo de trabajo de soporte técnico |

### Fase de exfiltración o impacto

| <b>Amenaza</b>                                 | <b>Mitigación</b>                                                                                             |
|------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| <b>Exfiltración de datos confidenciales</b>    | Implementar cifrado de datos, dlp (data loss prevention), monitoreo de tráfico saliente y control de accesos. |
| <b>Transferencia no autorizada de archivos</b> | Restringir dispositivos usb, aplicar filtros de correo y monitorear transferencias de archivos.               |
| <b>Eliminación o alteración de información</b> | Realizar copias de seguridad, aplicar controles de integridad y gestionar permisos de acceso.                 |
| <b>Divulgación de información sensible</b>     | Clasificar la información, aplicar cifrado y políticas de confidencialidad.                                   |
| <b>Interrupción de servicios</b>               | Contar con planes de continuidad de negocio, redundancia y recuperación ante desastres.                       |

## Arquitectura de red

### Diagnóstico de red actual

Actualmente, la empresa cuenta con una arquitectura de red básica que permite la operación de los servicios tecnológicos, la infraestructura presenta múltiples debilidades tanto a nivel físico como lógico que incrementan significativamente el riesgo de incidentes de seguridad informática.

En el aspecto físico, la red es vulnerable a fallas ocasionadas por cortes de cableado, deterioro de conectores, ausencia de redundancia y deficiencias en la organización del cableado estructurado, lo que podría generar interrupciones en la disponibilidad de los servicios y afectar la continuidad operativa de la empresa. Asimismo, no se evidencian mecanismos adecuados de protección física sobre los dispositivos y puntos de conexión de la red.

A nivel lógico, la infraestructura carece de una segmentación adecuada de la red, lo que representa un riesgo crítico de seguridad. Actualmente, los diferentes dispositivos, usuarios y servicios comparten el mismo segmento de red, permitiendo que un acceso no autorizado o un equipo comprometido pueda propagarse fácilmente hacia toda la infraestructura tecnológica. Esta situación aumenta la probabilidad de ataques internos, propagación de malware, acceso indebido a información sensible y compromisos generales de la confidencialidad, integridad y disponibilidad de los datos corporativos.

Además, la ausencia de controles de acceso, políticas de segmentación mediante VLANs y mecanismos de monitoreo de tráfico dificulta la detención temprana de actividades maliciosas dentro de la red empresarial.

### Arquitectura de red segura

Para la implementación de una arquitectura de red segura se toman como referencia las buenas prácticas establecidas en ISO/IEC 27001 para la seguridad de la información y la norma TIA/EIA-568 para el cableado estructurado. Estas normas proporcionan lineamientos y estándares orientados a fortalecer la seguridad lógica y física de la infraestructura tecnológica de la empresa.

La aplicación de ISO/IEC 27001 permite establecer controles de seguridad enfocados en la protección de la red, control de accesos, segmentación de servicios, gestión de riesgos y prevención de accesos no autorizados, contribuyendo a garantizar la confidencialidad, integridad y disponibilidad de la información.

Por otra parte, la norma TIA/EIA-568 establece los estándares para la correcta implementación del cableado estructurado, incluyendo la organización física de la red, distribución del cableado, conectividad y uso adecuado de dispositivos de telecomunicaciones, permitiendo una infraestructura más estable, escalable y resistente ante fallas físicas.

La combinación de ambas normas permite reducir el riesgo de amenazas internas y externas, mejorar la administración de la red y garantizar una arquitectura tecnológica más segura, eficiente y preparada para el crecimiento futuro de la organización.

### Infraestructura Física y Cableado Estructurado (Cumplimiento TIA/EIA-568 e ISO 27001 A.7.10)

Toda la conectividad física se despliega siguiendo el estándar **TIA/EIA-568** para cableado estructurado en edificios comerciales, asegurando el rendimiento de los datos y la resiliencia física:

- **Medio de Transmisión:** Se utiliza cableado de par trenzado **Categoría 6 (Cat 6)** para el cableado horizontal, garantizando transferencias de hasta 1 Gbps (y soporte de hasta 10 Gbps en distancias cortas), minimizando el crosstalk y la interferencia electromagnética.
- **Seguridad Física del Cableado (ISO 27001 A.7.10):** Los tendidos de cable se canalizan a través de escalerillas y tuberías cerradas para evitar manipulaciones maliciosas o daños accidentales. Los puntos de consolidación terminan en switches alojados exclusivamente dentro de gabinetes (*racks*) de comunicaciones bajo llave, ubicados en el Cuarto de Telecomunicaciones (TR).

### Perímetro de Red y Seguridad Fronteriza

El punto de entrada y salida de la red corporativa está rigurosamente controlado por una arquitectura de seguridad perimetral

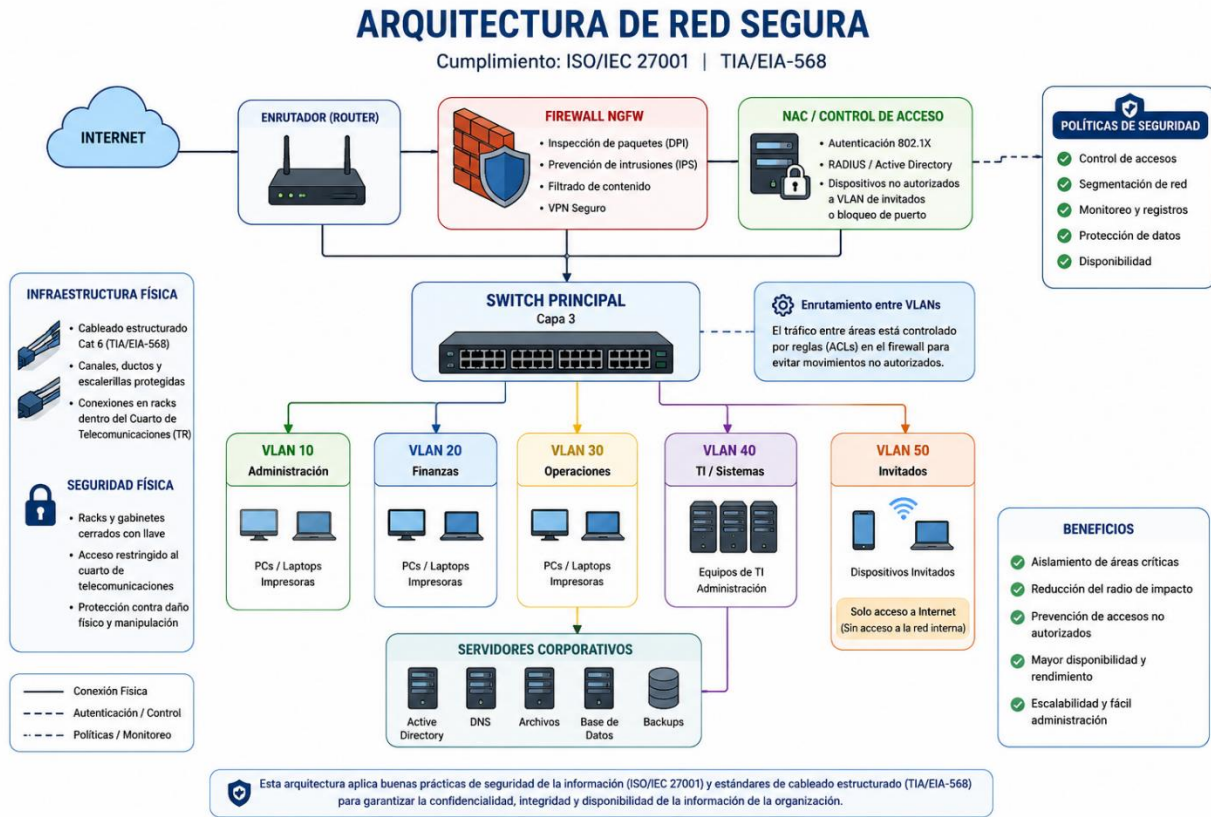
- **Enrutador Central y Firewall de Próxima Generación (NGFW):** El tráfico entrante y saliente es gestionado por un enrutador central integrado con un Firewall de red activo. Este dispositivo ejecuta inspección profunda de paquetes (DPI), prevención de intrusiones (IPS) y filtrado de contenido.
- **Control de Acceso a la Red (NAC / ISO 27001 A.8.20 & A.8.21):** No se permite la conexión directa (*Plug-and-Play*) de ningún dispositivo. El registro en la red requiere **autenticación obligatoria** mediante el protocolo **802.1X**. Cualquier dispositivo físico o inalámbrico que intente conectarse debe ser validado contra un servidor de identidades (como un Active Directory o RADIUS). Si no está autorizado, se aísla automáticamente en una VLAN de invitados o se bloquea el puerto del switch.

### Segmentación Lógica de la Red (Mitigación de Impacto e ISO 27001 A.8.22)

Para evitar el movimiento lateral de amenazas y garantizar que un fallo o compromiso en un sector no afecte a toda la organización, se implementa una **arquitectura segmentada mediante switches de Capa 2 / Capa 3**

- **Segmentación por Áreas (VLANs):** El switch principal distribuye la red en redes de área local virtuales (VLANs) independientes para segmentar los departamentos clave (ej. *VLAN 10: Administración, VLAN 20: Finanzas, VLAN 30: Operaciones, VLAN 40: TI/Sistemas, VLAN 50: Invitados*).
- **Aislamiento de Fallos y Blast Radius:** Esta configuración reduce el "radio de impacto" (*blast radius*). Si una estación de trabajo es infectada por malware en el área de Operaciones, las reglas de control de acceso (ACLs) entre VLANs impedirán que el tráfico malicioso se propague hacia las áreas críticas como Finanzas o los servidores centrales.
- **Políticas de Inter-VLAN Routing:** El enrutamiento entre las diferentes áreas está estrictamente restringido en el Firewall central. Las áreas solo pueden comunicarse entre sí si existe una justificación operativa explícita y aprobada por el área de ciberseguridad.

## Diagrama arquitectura de red



## Seguridad a nivel de aplicación y sistemas de gestión

La organización cuenta con plataformas críticas para la operación diaria, divididas principalmente en el **Sistema de Gestión Interna (ERP/CMS)** —que centraliza la propiedad intelectual y datos de terceros— y el **Sistema de Control de Activos y Maquinaria**. Con el fin de mitigar riesgos de filtración de información, accesos no autorizados o alteración de registros, se establecen los siguientes lineamientos de seguridad:

### Sistema de Gestión Interna (ERP y Repositorio de Información)

Este sistema maneja la carga de archivos críticos (planos, renderizados, diagramas) y almacena el registro de usuarios y clientes. Su protección se rige bajo los siguientes controles:

- Seguridad en la Carga de Archivos (File Upload Security):
  1. **Validación de Extensiones y Tipos MIME:** Se prohíbe estrictamente la carga de archivos ejecutables o scripts (.exe, .sh, .php, .js). Solo se permitirán formatos autorizados de diseño y documentación (ej. .pdf, .dwg, .rvt, .png, .jpg).
  2. **Sanitización de Nombres:** El sistema renombrará automáticamente los archivos subidos utilizando hashes únicos (ej. UUID) para evitar ataques de *Directory Traversal* o inyecciones de código a través del nombre del archivo.
  3. **Escaneo Antimalware:** Todo archivo cargado por un usuario o cliente debe ser inspeccionado por un motor antivirus/antimalware en tiempo real antes de ser almacenado permanentemente.
  4. **Almacenamiento Aislado:** Los archivos se almacenarán en un servidor de archivos o contenedor de almacenamiento (Blob Storage) aislado del servidor web principal, sin permisos de ejecución directa.

- **Protección de Datos de Clientes y Usuarios:**

1. **Control de Acceso Basado en Roles (RBAC):** Se implementará un principio de "menor privilegio". Los clientes solo tendrán acceso a sus propios proyectos y renders, mientras que el personal interno accederá únicamente a los módulos necesarios para sus funciones.
2. **Cifrado de Datos:** Los datos sensibles de clientes y las contraseñas de los usuarios deben cifrarse. Las contraseñas se almacenarán utilizando algoritmos de hashing seguros (como **BCrypt** o **Argon2**).

## Sistema de Administración de Herramientas y Maquinaria

Este sistema es vital para la continuidad del negocio y la logística de los proyectos. Para asegurar la integridad de los inventarios y la trazabilidad de los activos, se aplican los siguientes controles:

- **Integridad y No Repudio de Registros:**
  - Toda asignación, salida, retorno o reporte de daños de maquinaria y herramientas debe generar un registro de auditoría (*Audit Log*) inalterable. Este log debe registrar: ID del usuario, fecha, hora, acción realizada e ID del equipo.
- **Autenticación Robusta:**
  - El acceso al sistema de control de inventario estará restringido al personal de almacén y operaciones debidamente autenticado. Se evaluará la implementación de códigos de barras o tecnología **RFID** vinculada a las credenciales del usuario para evitar errores humanos en el inventario.

## Implementación de backups en archivos

Un aspecto fundamental dentro de la estrategia de seguridad de la información es la implementación de mecanismos de respaldo (backups) para los archivos y documentos utilizados por la empresa. Estos respaldos permiten garantizar la disponibilidad e integridad de la información ante incidentes como fallos de hardware, errores humanos, ataques informáticos, corrupción de datos o desastres naturales.

Para ello, se recomienda establecer una política de copias de seguridad periódicas, almacenando los respaldos en ubicaciones seguras y, de ser posible, en medios independientes al sistema principal. Asimismo, es importante realizar pruebas de restauración de forma regular para verificar que la información pueda recuperarse correctamente cuando sea necesario.

La implementación de respaldos contribuye a reducir el impacto de posibles incidentes de seguridad y asegura la continuidad de las operaciones de la organización.

# MONITOREO, DETECCIÓN Y OPERACIONES DE SEGURIDAD (SecOps)

## Estrategia de Monitoreo Continuo de la Infraestructura

El monitoreo continuo constituye uno de los pilares fundamentales de la ciberseguridad moderna, ya que permite identificar actividades sospechosas, fallas operativas y posibles incidentes de seguridad en tiempo real. Para Construservices se propone implementar una estrategia de supervisión permanente sobre los servidores, estaciones de trabajo, dispositivos de red, aplicaciones empresariales y sistemas de almacenamiento.

La estrategia contempla la recolección constante de registros de eventos (logs), monitoreo del tráfico de red, supervisión del rendimiento de los sistemas y detección de comportamientos anómalos que puedan representar una amenaza para la organización.

Entre los principales elementos a monitorear se encuentran:

- Intentos de acceso a sistemas corporativos.
- Actividad de usuarios privilegiados.
- Cambios en configuraciones críticas.
- Estado de servidores y bases de datos.
- Tráfico de red interno y externo.
- Transferencia de archivos sensibles.
- Eventos relacionados con malware o ransomware.

El monitoreo continuo permitirá detectar incidentes de forma temprana y reducir significativamente los tiempos de respuesta ante amenazas.

## Implementación de Soluciones SIEM (Security Information and Event Management)

Como parte de la estrategia de seguridad se propone la implementación de una plataforma SIEM (Security Information and Event Management), encargada de centralizar y analizar los registros generados por toda la infraestructura tecnológica de la empresa.

La solución SIEM recopilará información proveniente de:

- Firewalls.
- Servidores.
- Sistemas operativos.
- Bases de datos.
- Aplicaciones corporativas.
- Equipos de red.
- Sistemas EDR/XDR.

Entre las soluciones que pueden implementarse se encuentran:

- Wazuh.
- Splunk.
- IBM QRadar.
- Microsoft Sentinel.

La utilización de un SIEM permitirá identificar patrones de ataque, correlacionar eventos de diferentes fuentes y generar alertas automáticas cuando se detecten actividades potencialmente maliciosas.

### Despliegue de Agentes EDR/XDR en Estaciones de Trabajo y Servidores

Para fortalecer la capacidad de detección y respuesta ante amenazas avanzadas se propone la implementación de soluciones EDR (Endpoint Detection and Response) y XDR (Extended Detection and Response) en todos los equipos críticos de la organización.

Estas herramientas permitirán:

- Detectar malware avanzado.
- Identificar comportamientos sospechosos.
- Bloquear procesos maliciosos.
- Aislar equipos comprometidos.
- Analizar incidentes de seguridad.

Los agentes deberán instalarse en:

- Estaciones de trabajo de ingeniería.
- Equipos de renderizado.
- Servidores corporativos.
- Equipos administrativos.
- Dispositivos utilizados por personal con acceso privilegiado.

La utilización de EDR/XDR permitirá una respuesta rápida ante incidentes y reducirá significativamente el impacto de posibles ataques.

### Correlación de Eventos y Gestión de Alertas de Seguridad

La correlación de eventos consiste en analizar múltiples registros provenientes de diferentes sistemas para identificar patrones que puedan indicar un incidente de seguridad.

Por ejemplo, un intento fallido de autenticación por sí solo puede no representar una amenaza. Sin embargo, si se detectan múltiples intentos fallidos seguidos de un acceso exitoso desde una ubicación inusual, el sistema puede generar una alerta de riesgo elevado.

Algunos eventos que deberán generar alertas automáticas son:

- Más de cinco intentos fallidos de autenticación.
- Accesos fuera del horario laboral.
- Escalación de privilegios.
- Desactivación de antivirus.
- Modificaciones no autorizadas en servidores.
- Transferencias masivas de información.

- Conexión de dispositivos externos no autorizados.
- Detección de malware o ransomware.

Las alertas deberán clasificarse según su criticidad:

| Nivel   | Descripción                           |
|---------|---------------------------------------|
| Bajo    | Eventos informativos                  |
| Medio   | Actividad sospechosa                  |
| Alto    | Posible incidente                     |
| Crítico | Ataque confirmado o compromiso activo |

### Propuesta de Indicadores Clave de Seguridad (KPIs y KRIs)

Para evaluar la efectividad de los controles implementados se propone establecer indicadores de desempeño y riesgo relacionados con la seguridad de la información.

#### KPIs (Indicadores de Desempeño)

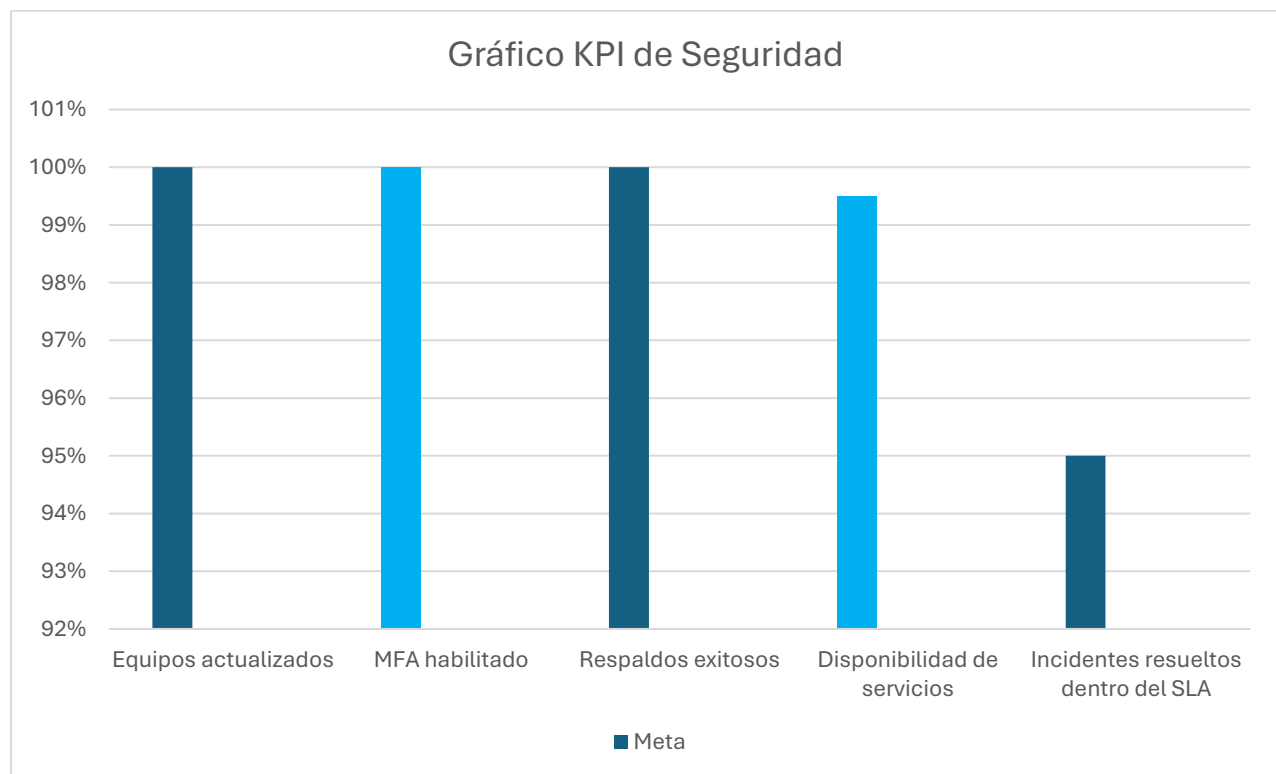
| Indicador                           | Objetivo |
|-------------------------------------|----------|
| Equipos actualizados                | 100%     |
| Usuarios con MFA habilitado         | 100%     |
| Incidentes resueltos dentro del SLA | >95%     |
| Disponibilidad de sistemas críticos | >99.5%   |
| Respaldos exitosos                  | 100%     |

#### KRIs (Indicadores de Riesgo)

| Indicador                          | Umbral                  |
|------------------------------------|-------------------------|
| Intentos de acceso no autorizado   | Menor a 20 por mes      |
| Equipos sin actualización          | Menor al 5%             |
| Incidentes críticos                | Menor a 2 por trimestre |
| Vulnerabilidades críticas abiertas | 0                       |
| Correos de phishing detectados     | Monitoreo continuo      |

*KPI de Seguridad*

| INDICADOR                           | META  |
|-------------------------------------|-------|
| EQUIPOS ACTUALIZADOS                | 100%  |
| MFA HABILITADO                      | 100%  |
| RESPALDOS EXITOSOS                  | 100%  |
| DISPONIBILIDAD DE SERVICIOS         | 99.5% |
| INCIDENTES RESUELTOS DENTRO DEL SLA | 95%   |



## PLAN DE RESPUESTA A INCIDENTES Y CONTINUIDAD DEL NEGOCIO (BCP/DRP)

### Definición y Clasificación de Incidentes de Ciberseguridad

Un incidente de ciberseguridad es cualquier evento que comprometa o tenga el potencial de comprometer la confidencialidad, integridad o disponibilidad de la información y los sistemas tecnológicos de Construservices.

Los incidentes pueden clasificarse según su impacto y criticidad:

| NIVEL          | DESCRIPCIÓN                                                                                                       |
|----------------|-------------------------------------------------------------------------------------------------------------------|
| <b>BAJO</b>    | Incidentes con impacto mínimo y sin afectación operativa significativa.                                           |
| <b>MEDIO</b>   | Eventos que afectan parcialmente algunos servicios o usuarios.                                                    |
| <b>ALTO</b>    | Incidentes que afectan sistemas críticos o información sensible.                                                  |
| <b>CRÍTICO</b> | Eventos que comprometen la continuidad operativa de la empresa o provocan pérdidas significativas de información. |

Entre los principales incidentes considerados se encuentran:

- Ataques de ransomware.
- Fuga de información confidencial.
- Accesos no autorizados.
- Infecciones por malware.
- Ataques de phishing.
- Denegación de servicio.
- Fallos en servidores críticos.
- Robo o pérdida de dispositivos corporativos.

## Roles y Responsabilidades del Comité de Crisis y Equipo de Respuesta (CSIRT)

Para garantizar una respuesta eficiente ante incidentes se propone la creación de un Equipo de Respuesta a Incidentes de Seguridad Informática (CSIRT).

### *Coordinador de Seguridad*

Responsable de dirigir las actividades de respuesta, coordinar recursos y tomar decisiones estratégicas durante la gestión del incidente.

### *Administrador de Sistemas*

Encargado de identificar sistemas afectados, aplicar medidas de contención y ejecutar actividades de recuperación.

### *Administrador de Redes*

Responsable del aislamiento de segmentos comprometidos, monitoreo de tráfico sospechoso y restauración de servicios de red.

### *Responsable de Comunicación*

Gestiona la comunicación interna y externa relacionada con el incidente, incluyendo clientes, proveedores y dirección ejecutiva.

### *Dirección General*

Aprueba decisiones críticas relacionadas con la continuidad del negocio y asignación de recursos extraordinarios.

## Protocolos de Contención, Erradicación y Recuperación

La gestión de incidentes se desarrollará mediante las siguientes fases:

### Identificación

Consiste en detectar y validar la existencia del incidente mediante herramientas de monitoreo, alertas automáticas o reportes de usuarios.

### Contención

Se aplican medidas inmediatas para evitar la propagación del incidente.

Ejemplos:

- Aislamiento de equipos comprometidos.
- Bloqueo de cuentas afectadas.
- Restricción temporal de accesos.

### Erradicación

Eliminación de la causa raíz del incidente.

Ejemplos:

- Eliminación de malware.
- Corrección de vulnerabilidades.
- Actualización de sistemas comprometidos.

### Recuperación

Restablecimiento seguro de los servicios afectados mediante respaldos y procedimientos de restauración.

### Lecciones Aprendidas

Una vez finalizada la gestión del incidente, se debe realizar un proceso de análisis y documentación de las lecciones aprendidas con el objetivo de fortalecer los controles de seguridad y reducir la probabilidad de que eventos similares ocurran en el futuro.

Toda la información relacionada con el incidente debe quedar debidamente registrada, incluyendo la causa raíz, los sistemas afectados, las acciones de contención, erradicación y recuperación ejecutadas, así como la efectividad de las medidas implementadas. Esta documentación permite generar una base de conocimiento institucional que facilite la respuesta ante incidentes futuros y contribuya a la mejora continua del Sistema de Gestión de Seguridad de la Información (SGSI).

Asimismo, las lecciones aprendidas servirán como material de apoyo para la capacitación y formación de los miembros actuales y futuros del Comité de Seguridad de la Información, promoviendo una mayor concienciación sobre las amenazas, vulnerabilidades y procedimientos de respuesta establecidos por la organización.

Como resultado de este análisis, se deberán identificar oportunidades de mejora en las políticas, procedimientos, controles de seguridad y programas de capacitación, garantizando el fortalecimiento continuo de la postura de ciberseguridad de la empresa.

## Protocolo ante Ataques de Ransomware (Secuestro de Renders y Planos)

Debido a que Construservices almacena planos digitales, modelos 3D y documentación técnica crítica, un ataque de ransomware representa una de las amenazas más graves para la organización.

### Procedimiento de respuesta

1. Detectar actividad sospechosa o cifrado de archivos.
2. Desconectar inmediatamente los equipos afectados de la red.
3. Bloquear accesos comprometidos.
4. Identificar el alcance del ataque.
5. Verificar integridad de respaldos.
6. Restaurar la información desde copias de seguridad seguras.
7. Analizar el origen del ataque.
8. Actualizar controles de seguridad.
9. Elaborar informe final del incidente.

### Protocolo ante Fuga de Datos de la Cartera de Clientes

La exposición de información relacionada con clientes, contratos y proyectos puede generar consecuencias financieras, legales y reputacionales.

### Procedimiento de respuesta

1. Detectar la posible fuga de información.
2. Determinar qué datos fueron comprometidos.
3. Suspender accesos involucrados.
4. Identificar al responsable o vector de ataque.
5. Contener la filtración.
6. Recuperar la seguridad de los sistemas afectados.
7. Notificar a la dirección de la empresa.
8. Documentar el incidente.
9. Implementar medidas correctivas.

## Política y Estrategia de Respaldos (Backup) Inmutables y Regla 3-2-1

Para garantizar la recuperación de información ante incidentes de seguridad se implementará una estrategia de respaldos basada en la regla 3-2-1.

Esta estrategia establece:

- Mantener tres copias de la información.
- Utilizar dos medios de almacenamiento diferentes.
- Mantener una copia fuera de las instalaciones.

Los respaldos deberán incluir:

- Bases de datos corporativas.
- Información financiera.
- Planos y diseños digitales.
- Sistemas de gestión de clientes.
- Sistemas de gestión de maquinaria.

Además, se recomienda implementar respaldos inmutables que no puedan ser modificados ni eliminados por software malicioso.

Las pruebas de restauración deberán realizarse periódicamente para garantizar la efectividad de los respaldos.

## Plan de Continuidad del Negocio (BCP) para Operaciones en San Miguel

El Plan de Continuidad del Negocio tiene como objetivo garantizar que Construservices pueda mantener sus operaciones esenciales ante eventos que afecten la infraestructura tecnológica.

Los servicios críticos identificados son:

- Sistema de gestión de clientes.
- Sistema de gestión de maquinaria.
- Bases de datos corporativas.
- Infraestructura de red.
- Servidores de almacenamiento.
- Equipos de diseño y renderizado.

### Estrategias de continuidad

- Disponibilidad de respaldos actualizados.
- Infraestructura redundante para servicios críticos.
- Procedimientos documentados de recuperación.
- Capacitación periódica del personal.
- Simulacros de recuperación ante desastres.

### Objetivos de recuperación

| <b>Servicio</b>                     | <b>RTO</b> | <b>RPO</b> |
|-------------------------------------|------------|------------|
| <b><i>Sistema de Clientes</i></b>   | 4 horas    | 1 hora     |
| <b><i>Base de Datos</i></b>         | 2 horas    | 30 minutos |
| <b><i>Sistema de Maquinaria</i></b> | 6 horas    | 2 horas    |
| <b><i>Archivos de Proyectos</i></b> | 8 horas    | 4 horas    |
| <b><i>Correo Corporativo</i></b>    | 4 horas    | 1 hora     |

La implementación de este plan permitirá a Construservices minimizar interrupciones operativas, proteger sus activos críticos de información y mantener la continuidad de sus proyectos de construcción ante incidentes tecnológicos o cibernéticos.

## Plan de capacitación de usuarios

Debido al incremento constante de los ataques de ingeniería social, especialmente aquellos basados en phishing, resulta fundamental implementar un programa de capacitación y concienciación en ciberseguridad dirigido a todo el personal de la organización.

Este plan estará enfocado principalmente en los usuarios con menor experiencia en el uso de sistemas corporativos y en aquellos que no poseen conocimientos básicos sobre seguridad de la información, ya que suelen representar un mayor riesgo de exposición ante amenazas cibernéticas.

Las capacitaciones tendrán como objetivo desarrollar una cultura de seguridad dentro de la empresa, permitiendo a los colaboradores identificar y reportar correos electrónicos sospechosos, intentos de fraude, enlaces maliciosos, archivos adjuntos potencialmente peligrosos y otras técnicas utilizadas por los ciberdelincuentes para obtener acceso no autorizado a la información corporativa.

Asimismo, se promoverán buenas prácticas relacionadas con la gestión de contraseñas, el uso seguro del correo electrónico, la protección de la información sensible, la navegación segura en Internet y el cumplimiento de las políticas de seguridad establecidas por la organización.

El programa de capacitación deberá realizarse de forma periódica y complementarse con campañas de sensibilización, evaluaciones de conocimiento y simulaciones de ataques de phishing, con el propósito de medir el nivel de preparación de los usuarios y fortalecer continuamente la postura de ciberseguridad de la empresa. Las simulaciones de ataques de phishing son cruciales porque evalúan un riesgo latente y constante en la organización y de esta forma se puede hacer un análisis y filtrado de los usuarios que siguen siendo posibles víctimas a estos ataques, además se tienen que establecer normativas y sanciones para los usuarios a pesar de estar capacitados sigan siendo víctimas de simulaciones de phishing, la simulaciones se tienen que llevar a cabo por el equipo encargado en ciberseguridad dentro de la empresa.

## Tabla de planificación

| <i>Actividad</i>                               | <i>Frecuencia</i> | <i>Público Objetivo</i>              |
|------------------------------------------------|-------------------|--------------------------------------|
| <i>Capacitación en phishing</i>                | Trimestral        | Todo el personal                     |
| <i>Gestión segura de contraseñas</i>           | Semestral         | Todo el personal                     |
| <i>Simulación de phishing</i>                  | Trimestral        | Todo el personal                     |
| <i>Manejo de información sensible</i>          | Semestral         | Personal administrativo y financiero |
| <i>Actualización de políticas de seguridad</i> | Anual             | Todo el personal                     |

Con todas estas acciones se espera que los usuarios dentro de la empresa también se encuentren bien capacitados, teniendo una efectividad mayor en la seguridad de la información dentro de la empresa, asegurando barreras de ciberseguridad robustas para prevenir los posibles ataques y solventar los incidentes de ciberseguridad.

## Evaluación de Madurez de Controles de Seguridad

La evaluación de madurez permite determinar en qué nivel de desarrollo se encuentran los controles de seguridad dentro de la organización. Se utilizó una escala del 1 al 5, donde 1 representa ausencia de controles formales y 5 representa un control optimizado y gestionado continuamente.

| Dominio de Control                         | Nivel Actual (1-5)     | Nivel Objetivo        |
|--------------------------------------------|------------------------|-----------------------|
| Control de acceso e identidades            | <b>2 - Inicial</b>     | <b>4 - Gestionado</b> |
| Segmentación y seguridad de red            | <b>1 - Inexistente</b> | <b>4 - Gestionado</b> |
| Gestión de vulnerabilidades                | <b>2 - Inicial</b>     | <b>4 - Gestionado</b> |
| Respaldo y recuperación (BCP/DRP)          | <b>2 - Inicial</b>     | <b>5 - Optimizado</b> |
| Concienciación y capacitación del personal | <b>1 - Inexistente</b> | <b>4 - Gestionado</b> |
| Monitoreo y detección de amenazas          | <b>1 - Inexistente</b> | <b>4 - Gestionado</b> |

## Evaluación de Cumplimiento Normativo

A continuación, se presenta el nivel de cumplimiento actual de Construservices respecto a los marcos y estándares de referencia aplicados en este análisis. El porcentaje refleja la proporción de controles o requisitos que la organización cumple actualmente de forma verificada.

| Marco / Norma | Cumplimiento Actual | Observación                                                         |
|---------------|---------------------|---------------------------------------------------------------------|
| ISO/IEC 27001 | 35%                 | Ausencia de SGSI formal, sin política documentada                   |
| NIST CSF      | 40%                 | Funciones de Proteger y Detectar con brechas significativas         |
| MITRE ATT&CK  | 25%                 | Sin controles de detección y respuesta ante TTP documentados        |
| TIA/EIA-568   | 60%                 | Infraestructura parcialmente estructurada, sin certificación formal |

## Recomendaciones Estratégicas

Con base en el análisis realizado, se proponen las siguientes acciones estratégicas clasificadas por horizonte temporal de implementación:

| Plazo                            | Acción Recomendada                                            | Prioridad      |
|----------------------------------|---------------------------------------------------------------|----------------|
| <b>Corto Plazo (0-3 meses)</b>   | Implementar MFA en todos los accesos a sistemas críticos      | <b>Crítica</b> |
| <b>Corto Plazo (0-3 meses)</b>   | Activar respaldos automatizados bajo regla 3-2-1              | <b>Crítica</b> |
| <b>Mediano Plazo (3-9 meses)</b> | Implementar segmentación de red mediante VLANs                | <b>Alta</b>    |
| <b>Mediano Plazo (3-9 meses)</b> | Desplegar solución EDR/XDR y SIEM para monitoreo continuo     | <b>Alta</b>    |
| <b>Largo Plazo (9-18 meses)</b>  | Iniciar proceso de alineación con ISO/IEC 27001 (SGSI formal) | <b>Media</b>   |

## Hoja de Ruta (Roadmap de Implementación)

El roadmap de ciberseguridad define las fases de implementación de los controles y mejoras propuestas, organizadas en tres horizontes temporales. Este plan permite a la dirección de Construservices priorizar inversiones y asignar responsabilidades de manera ordenada.

| Fase                              | Período     | Actividades Clave                                                    | Responsable                           |
|-----------------------------------|-------------|----------------------------------------------------------------------|---------------------------------------|
| <b>Fase 1<br/>Fundamentos</b>     | Meses 1-3   | MFA, política de contraseñas, inventario de activos, respaldos 3-2-1 | Administrador de Sistemas / CSIRT     |
| <b>Fase 2<br/>Fortalecimiento</b> | Meses 4-9   | VLANs, NGFW, EDR/XDR, SIEM, capacitación anti-phishing               | Adm. Redes / Coordinador de Seguridad |
| <b>Fase 3<br/>Madurez</b>         | Meses 10-18 | SGSI ISO 27001, simulacros DRP, auditorías internas, mejora continua | Dirección General / CSIRT             |

## Conclusión

### Importancia del documento

El presente Manual de Ciberseguridad Empresarial establece los lineamientos, políticas, procedimientos y controles necesarios para proteger los activos de información de la organización frente a las amenazas y riesgos del entorno digital actual. Cada uno de los aspectos desarrollados se fundamenta en normas, estándares y buenas prácticas reconocidas internacionalmente, tales como ISO/IEC 27001 y TIA/EIA-568, con el propósito de garantizar una gestión adecuada de la seguridad de la información.

La implementación de los controles descritos en este documento permite fortalecer la confidencialidad, integridad y disponibilidad de la información, reduciendo la probabilidad de incidentes de seguridad que puedan afectar las operaciones, la reputación o los recursos de la empresa. Asimismo, contribuye a la identificación temprana de amenazas, la correcta gestión de vulnerabilidades y la respuesta efectiva ante posibles incidentes de ciberseguridad.

De igual manera, se destaca la importancia de la participación activa de todo el personal en la protección de la información. La seguridad no depende únicamente de las herramientas tecnológicas implementadas, sino también del compromiso de los usuarios para cumplir las políticas establecidas, adoptar buenas prácticas y participar en los programas de capacitación y concienciación definidos por la organización.

La aplicación de una arquitectura de red segura, mecanismos de control de acceso, planes de respaldo, procedimientos de respuesta a incidentes y programas de formación continua permite construir una cultura organizacional orientada a la seguridad, capaz de adaptarse a nuevas amenazas y desafíos tecnológicos.

Finalmente, este documento debe considerarse como una guía dinámica y en constante actualización, que deberá revisarse periódicamente para incorporar nuevos controles, tecnologías y requisitos normativos, asegurando que la empresa mantenga una postura de ciberseguridad sólida, resiliente y alineada con las mejores prácticas del sector.

## Anexos Técnicos

### A. Matriz de Activos de la Información

| ID | Activo                  | Tipo de Activo        | Descripción                                                                                              | Importancia | Información que contiene                                                                | Nivel de criticidad |
|----|-------------------------|-----------------------|----------------------------------------------------------------------------------------------------------|-------------|-----------------------------------------------------------------------------------------|---------------------|
| 1  | Base de datos           | Información /Software | Sistema encargado de almacenar toda la información crítica de la empresa y de los sistemas internos.     | Muy Alta    | Datos de empleados, clientes, reportes, historiales, proyectos, ventas y transacciones. | Crítico             |
| 2  | Aplicaciones de Gestión | Software              | Sistemas utilizados para la administración de empleados, clientes y maquinaria de construcción.          | Alta        | Información operativa, registros administrativos y control de maquinaria                | Alto                |
| 3  | Información Financiera  | Información           | Información económica y financiera de la empresa utilizada para operaciones administrativas y contables. | Muy Alta    | Cuentas bancarias, historial de pagos, datos de socios, clientes y empleados.           | Crítico             |

### B. Evaluación de riesgos



| <b>Vulnerabilidad</b>               | <b>Criticidad</b> |
|-------------------------------------|-------------------|
| <i>Falta de segmentación de red</i> | <b>Crítica</b>    |
| <i>Ausencia de MFA</i>              | <b>Crítica</b>    |
| <i>Contraseñas débiles</i>          | <b>Alta</b>       |
| <i>Escaso monitoreo</i>             | <b>Alta</b>       |
| <i>Sistemas desactualizados</i>     | <b>Alta</b>       |
| <i>Deficiencias en respaldos</i>    | <b>Alta</b>       |
| <i>Falta de capacitación</i>        | <b>Media</b>      |
| <i>Falta de RBAC</i>                | <b>Media</b>      |

### c. Matriz de riesgos

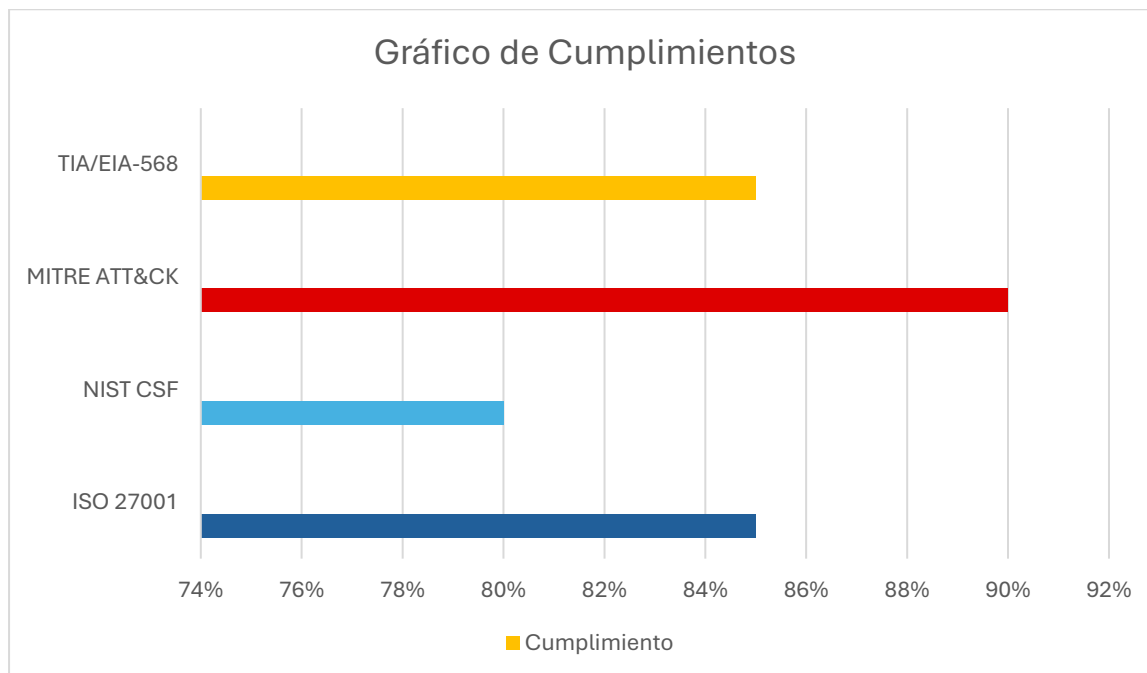
| <b>Riesgo</b>                            | <b>Probabilidad</b> | <b>Impacto</b> | <b>Nivel de Riesgo</b> |
|------------------------------------------|---------------------|----------------|------------------------|
| <b>Ransomware en servidores</b>          | <b>Alta</b>         | <b>Crítico</b> | <b>Crítico</b>         |
| <b>Fuga de información de clientes</b>   | <b>Media</b>        | <b>Crítico</b> | <b>Alto</b>            |
| <b>Acceso no autorizado</b>              | <b>Alta</b>         | <b>Alto</b>    | <b>Alto</b>            |
| <b>Pérdida de información por fallas</b> | <b>Media</b>        | <b>Alto</b>    | <b>Alto</b>            |
| <b>Phishing a empleados</b>              | <b>Alta</b>         | <b>Medio</b>   | <b>Alto</b>            |
| <b>Caída de la red corporativa</b>       | <b>Media</b>        | <b>Alto</b>    | <b>Alto</b>            |
| <b>Malware en estaciones de trabajo</b>  | <b>Alta</b>         | <b>Medio</b>   | <b>Alto</b>            |

## D. Evaluación de Madurez de Ciberseguridad

| DOMINIO            | NIVEL |
|--------------------|-------|
| GOBERNANZA         | 3     |
| GESTIÓN DE RIESGOS | 4     |
| PROTECCIÓN         | 3     |
| DETECCIÓN          | 2     |
| RESPUESTA          | 3     |
| RECUPERACIÓN       | 4     |

Cumplimiento de Marcos

| Estándar     | Cumplimiento |
|--------------|--------------|
| ISO 27001    | 85%          |
| NIST CSF     | 80%          |
| MITRE ATT&CK | 90%          |
| TIA/EIA-568  | 85%          |



## E. Amenazas y mitigaciones según fases

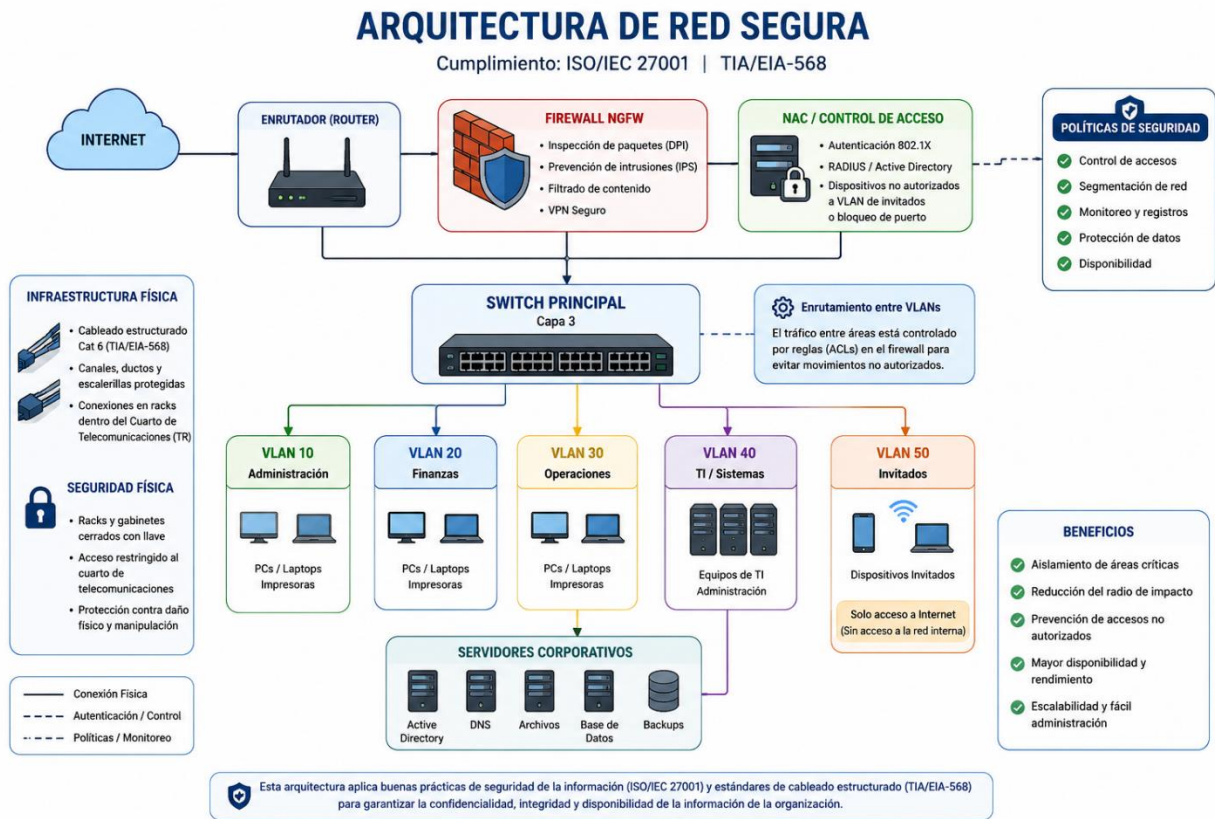
### Fase de reconocimiento

| Amenaza                                  | Mitigación                                                                                                                                                                                                                                                                                       |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Escaneo activo</b>                    | Esta técnica no puede mitigarse fácilmente con controles preventivos, ya que se basa en comportamientos realizados fuera del alcance de las defensas y controles empresariales. Los esfuerzos deberían centrarse en minimizar la cantidad y sensibilidad de los datos disponibles para terceros. |
| <b>Adquisición de acceso</b>             | Esta técnica no puede mitigarse fácilmente con controles preventivos, ya que se basa en comportamientos realizados fuera del alcance de las defensas y controles empresariales.                                                                                                                  |
| <b>Phishing para obtener información</b> | Se puede entrenar a los usuarios para identificar técnicas de ingeniería social e intentos de spearphishing                                                                                                                                                                                      |

### Fase de Acceso inicial

| Amenaza                            | Mitigación                                                                                                                                                                                                                                                                                                               |
|------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Inyección de contenido</b>      | Detectar creaciones de archivos sospechosas y ejecutar procesos desencadenados por actividad del navegador (por ejemplo, cargas útiles inyectadas escritas en directorios %appdata% o Temp, y luego ejecutadas). Correlacionar anomalías de red con la creación local de procesos o la ejecución de scripts posteriores. |
| <b>Incorporaciones de hardware</b> | Bloquea dispositivos y accesorios desconocidos mediante la configuración y el agente de monitorización de seguridad de endpoint.                                                                                                                                                                                         |
| <b>Redes wi-fi</b>                 | La segmentación de red puede utilizarse para aislar componentes de infraestructura que no requieren acceso amplio a la red. Entornos de red separados para redes wi-fi y cableadas por ethernet, especialmente donde las redes basadas en ethernet permiten el acceso a recursos sensibles                               |

F. Diagrama arquitectura de red

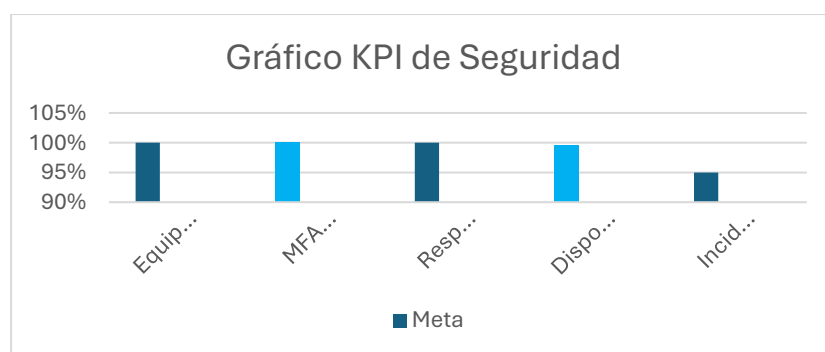


G. KPIs y KRIs de Seguridad

| Indicador                           | Objetivo                |
|-------------------------------------|-------------------------|
| Equipos actualizados                | 100%                    |
| Usuarios con MFA habilitado         | 100%                    |
| Incidentes resueltos dentro del SLA | >95%                    |
| Disponibilidad de sistemas críticos | >99.5%                  |
| Respaldos exitosos                  | 100%                    |
| Indicador                           | Umbral                  |
| Intentos de acceso no autorizado    | Menor a 20 por mes      |
| Equipos sin actualización           | Menor al 5%             |
| Incidentes críticos                 | Menor a 2 por trimestre |
| Vulnerabilidades críticas abiertas  | 0                       |
| Correos de phishing detectados      | Monitoreo continuo      |

## KPI de Seguridad

| INDICADOR                           | META  |
|-------------------------------------|-------|
| EQUIPOS ACTUALIZADOS                | 100%  |
| MFA HABILITADO                      | 100%  |
| RESPALDOS EXITOSOS                  | 100%  |
| DISPONIBILIDAD DE SERVICIOS         | 99.5% |
| INCIDENTES RESUELTOS DENTRO DEL SLA | 95%   |



## H. Definición y Clasificación de Incidentes de Ciberseguridad

| NIVEL          | DESCRIPCIÓN                                                                                                       |
|----------------|-------------------------------------------------------------------------------------------------------------------|
| <b>BAJO</b>    | Incidentes con impacto mínimo y sin afectación operativa significativa.                                           |
| <b>MEDIO</b>   | Eventos que afectan parcialmente algunos servicios o usuarios.                                                    |
| <b>ALTO</b>    | Incidentes que afectan sistemas críticos o información sensible.                                                  |
| <b>CRÍTICO</b> | Eventos que comprometen la continuidad operativa de la empresa o provocan pérdidas significativas de información. |

## I. Tabla de planificación

| <i>Actividad</i>                               | <i>Frecuencia</i> | <i>Público Objetivo</i>              |
|------------------------------------------------|-------------------|--------------------------------------|
| <i>Capacitación en phishing</i>                | Trimestral        | Todo el personal                     |
| <i>Gestión segura de contraseñas</i>           | Semestral         | Todo el personal                     |
| <i>Simulación de phishing</i>                  | Trimestral        | Todo el personal                     |
| <i>Manejo de información sensible</i>          | Semestral         | Personal administrativo y financiero |
| <i>Actualización de políticas de seguridad</i> | Anual             | Todo el personal                     |

## J. Evaluación de Madurez de Controles de Seguridad

| <b>Dominio de Control</b>                  | <b>Nivel Actual (1-5)</b> | <b>Nivel Objetivo</b> |
|--------------------------------------------|---------------------------|-----------------------|
| Control de acceso e identidades            | <b>2 - Inicial</b>        | <b>4 - Gestionado</b> |
| Segmentación y seguridad de red            | <b>1 - Inexistente</b>    | <b>4 - Gestionado</b> |
| Gestión de vulnerabilidades                | <b>2 - Inicial</b>        | <b>4 - Gestionado</b> |
| Respaldo y recuperación (BCP/DRP)          | <b>2 - Inicial</b>        | <b>5 - Optimizado</b> |
| Concienciación y capacitación del personal | <b>1 - Inexistente</b>    | <b>4 - Gestionado</b> |
| Monitoreo y detección de amenazas          | <b>1 - Inexistente</b>    | <b>4 - Gestionado</b> |

## Glosario

**Activo de Información:** Recurso físico o digital que posee valor para la organización y requiere protección.

**Amenaza:** Evento o acción con potencial de causar daño a los activos de información.

**Autenticación Multifactor (MFA):** Método de autenticación que requiere dos o más factores para verificar la identidad de un usuario.

**Backup:** Copia de seguridad utilizada para recuperar información en caso de pérdida o incidente.

**BCP (Business Continuity Plan):** Plan de continuidad del negocio diseñado para mantener las operaciones esenciales durante una interrupción.

**Confidencialidad:** Garantía de que la información solo sea accesible para personas autorizadas.

**CSIRT (Computer Security Incident Response Team):** Equipo encargado de gestionar y responder a incidentes de seguridad informática.

**Disponibilidad:** Capacidad de un sistema o servicio para estar accesible cuando sea requerido.

**DLP (Data Loss Prevention):** Conjunto de herramientas y controles destinados a prevenir la pérdida o fuga de información.

**EDR (Endpoint Detection and Response):** Solución que permite detectar, analizar y responder a amenazas en dispositivos finales.

**Firewall:** Dispositivo o software que controla y filtra el tráfico de red según reglas de seguridad definidas.

**Hash:** Valor generado mediante un algoritmo criptográfico utilizado para verificar la integridad de los datos.

**Incidente de Seguridad:** Evento que compromete la confidencialidad, integridad o disponibilidad de la información.

**Integridad:** Propiedad que garantiza que la información no ha sido alterada de manera no autorizada.

**ISO/IEC 27001:** Norma internacional para la gestión de la seguridad de la información.

**KPI (Key Performance Indicator):** Indicador utilizado para medir el desempeño de un proceso o control.

**KRI (Key Risk Indicator):** Indicador utilizado para monitorear niveles de riesgo dentro de la organización.

**Malware:** Software malicioso diseñado para dañar, alterar o comprometer sistemas informáticos.

**MITRE ATT&CK:** Marco de referencia que documenta tácticas y técnicas utilizadas por atacantes reales.

**NGFW (Next Generation Firewall):** Firewall avanzado con capacidades de inspección profunda y detección de amenazas.

**NIST CSF (Cybersecurity Framework):** Marco de referencia para la gestión de riesgos de ciberseguridad.

**Phishing:** Técnica de ingeniería social utilizada para obtener información sensible mediante engaños.

**Ransomware:** Tipo de malware que cifra archivos y exige un pago para recuperar el acceso a ellos.

**RBAC (Role Based Access Control):** Modelo de control de acceso basado en roles asignados a los usuarios.

**RPO (Recovery Point Objective):** Cantidad máxima de información que puede perderse tras un incidente.

**RTO (Recovery Time Objective):** Tiempo máximo permitido para recuperar un servicio después de una interrupción.

**SIEM (Security Information and Event Management):** Plataforma utilizada para recopilar, correlacionar y analizar eventos de seguridad.

**VLAN (Virtual Local Area Network):** Segmentación lógica de una red para mejorar el control y la seguridad del tráfico.

**VPN (Virtual Private Network):** Tecnología que permite establecer conexiones seguras a través de redes públicas.

**Vulnerabilidad:** Debilidad en un sistema, proceso o activo que puede ser explotada por una amenaza.

**XDR (Extended Detection and Response):** Plataforma de seguridad que integra múltiples fuentes para mejorar la detección y respuesta ante amenazas.

## Bibliografía

IBM. (s.f.). Obtenido de [www.ibm.com](https://www.ibm.com/mx-es/think/topics/nist): <https://www.ibm.com/mx-es/think/topics/nist>

ISO. (s.f.). *iso*. Obtenido de [www.iso.org](https://www.iso.org): <https://www.iso.org/es/norma/27001>

mitre. (s.f.). *attack.mitre*. Obtenido de [www.attack.mitre.org](https://www.attack.mitre.org): <https://attack.mitre.org/>

Mitre. (s.f.). *Mitre*. Obtenido de Mitre: <https://attack.mitre.org/>